COMPTIA SECURITY+ SY0-701 DOMÍNIO 4 · OPERAÇÕES DE SEGURANÇA (28%)

Security+ 4.3 · Analyzing Vulnerabilities

Mestre CyberSec · **Aula 4.3 — Analyzing Vulnerabilities** (10:29) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: CVSS 0-10: baixo 0.1-3.9; médio 4-6.9; alto 7-8.9; CRÍTICO 9-10. CVE=catálogo mundial. Prioriza por CVSS+exposição: crítico na internet = ontem.

💡 Highlights que a prova CompTIA cobra

- CVSS 9+ = crítico; 7+ = alto
- Prioridade = CVSS + EXPOSIÇÃO (na internet primeiro)

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'CVSS score of 9.8'=Critical

🧯 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 4.3 — Analyzing Vulnerabilities)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Sistema Comum de Pontuação de Vulnerabilidades (CVSS)
Estrutura aberta que atribui pontuação numérica de 0,0 a 10,0 a vulnerabilidades de software; a Security+ classifica 0,1–3,9 Baixa, 4,0–6,9 Média, 7,0–8,9 Alta e 9,0–10,0 Crítica.

⚠ ***Armadilha CompTIA:*** *Gatilho: 'CVSS score of 9.8' = Critical. Não confunda CVSS (severidade) com CVE (identificador).*

• Vulnerabilidades e Exposições Comuns (CVE)
Catálogo mundial padronizado e identificador para vulnerabilidades de segurança publicamente conhecidas, usando o formato CVE-AAAA-NNNNN.

⚠ ***Armadilha CompTIA:*** *CVE identifica a vulnerabilidade, mas não informa gravidade; use CVSS para pontuar e priorizar.*

• Base Nacional de Vulnerabilidades (NVD)
Repositório do governo dos EUA que enriquece registros CVE com pontuações CVSS, classificações CWE e dados de produtos afetados.

⚠ ***Armadilha CompTIA:*** *NVD é a base que adiciona análise e pontuação ao CVE; não é o mesmo que CVE.*

• Enumeração Comum de Fraquezas (CWE)
Catálogo de tipos comuns de fraquezas de software, como buffer overflow ou injeção SQL, que podem levar a vulnerabilidades.

⚠ ***Armadilha CompTIA:*** *CWE descreve a classe da fraqueza; CVE identifica uma instância específica dessa fraqueza.*

• Sistema de Pontuação de Previsão de Exploração (EPSS)
Sistema de pontuação que estima a probabilidade de uma vulnerabilidade ser explorada em ambiente real nos próximos 30 dias.

⚠ ***Armadilha CompTIA:*** *Ajuda a priorizar além do CVSS: EPSS alto + exposição à internet = ação urgente.*

• Catálogo de Vulnerabilidades Exploradas Conhecidas da CISA (KEV)
Catálogo da CISA de vulnerabilidades confirmadas como exploradas ativamente em ambiente real, com prazos exigidos de correção para agências federais dos EUA.

⚠ ***Armadilha CompTIA:*** *Se uma vulnerabilidade está no KEV, há exploração ativa; priorize acima de CVSS isolado.*

• Superfície de Ataque (N/A)

Soma de todos os possíveis pontos de entrada e ativos expostos que um atacante pode usar para explorar um sistema ou organização.

⚠️ ***Armadilha CompTIA:*** *Prioridade = CVSS + exposição: superfície voltada à internet com vulnerabilidade crítica deve ser corrigida imediatamente.*

• Falso Positivo (FP)

Resultado de scanner de vulnerabilidades que relata incorretamente uma vulnerabilidade ou problema que não existe de fato.

⚠️ ***Armadilha CompTIA:*** *Valide achados antes de remediar; falsos positivos consomem tempo e podem mascarar riscos reais.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Grupos de Métricas CVSS: Base, Temporal e Ambiental (CVSS Metric Groups)

🏠 **Analogia Intuitiva:** O diagnóstico médico de um vírus contagioso. A gravidade biológica natural do vírus no microscópio (Base: capacidade natural de causar febre e se espalhar); se já existe vacina na farmácia ou se o vírus está infectando milhares de pessoas na sua rua agora (Temporal: muda com o passar dos meses conforme surgem remédios ou mutações); a saúde específica do paciente individual (Ambiental: uma gripe para um atleta jovem de 20 anos é leve, mas para um idoso com comorbidades dentro de um asilo é mortal).

🔍 **Causa Raiz / Por que foi criado:** Tratar todas as vulnerabilidades apenas pela nota teórica do fabricante faz a empresa gastar recursos preciosos corrigindo computadores de teste isolados enquanto servidores de banco de dados vitais expostos à internet ficam desprotegidos.

🛡️ **Visão do Auditor de GRC:** O auditor de GRC fiscaliza se a política de gestão de vulnerabilidades utiliza a Métrica Ambiental do CVSS para elevar a prioridade de ativos críticos e se considera a criticidade do negócio (Business Impact Analysis).

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'CVSS metric group measuring qualities of a vulnerability that remain constant over time and across environments' = Base Metric. 'Metric modifying CVSS score based on organizational asset criticality and compensating controls' = Environmental Metric.

📌 Faixas de Severidade do CVSS v3.x (CVSS Severity Ratings: Low to Critical)

🏠 **Analogia Intuitiva:** A triagem hospitalar de pronto-socorro (Protocolo de Manchester). Um arranhão leve no braço é Verde/Baixo (0.1 a 3.9); uma dor de cabeça forte é Amarelo/Médio (4.0 a 6.9); uma fratura óssea é Laranja/Alto (7.0 a 8.9); e uma parada cardíaca súbita que exige reanimação imediata na sala de trauma é Vermelho/Crítico (9.0 a 10.0).

🔍 **Causa Raiz / Por que foi criado:** Sem uma régua objetiva de gravidade numérica, analistas entram em pânico com milhares de alertas, perdendo o foco nas falhas que causam destruição imediata dos negócios.

🛡️ **Visão do Auditor de GRC:** O auditor exige acordos formais de nível de serviço (SLA) atrelados à severidade do CVSS (exemplo: Crítico corrigido em até 48h; Alto em até 7 dias; Médio em até 30 dias), auditando os desvios de prazo.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'Vulnerability with a CVSS v3 score of 9.8' = Critical Severity. 'CVSS score range 7.0 to 8.9' = High Severity. 'CVSS score range 4.0 to 6.9' = Medium Severity.

📌 Vetor de Ataque e Facilidade de Exploração (Attack Vector & Exploitability)

🏠 **Analogia Intuitiva:** Uma fechadura que só pode ser violada se o ladrão estiver fisicamente dentro do cofre segurando ferramentas pesadas (Vetor Local/Físico com alta complexidade) versus uma porta automática que pode ser aberta por qualquer pessoa no mundo apertando um botão no celular sem senha alguma (Vetor de Rede remoto sem autenticação).

🔍 **Causa Raiz / Por que foi criado:** Uma falha de alto impacto teórico pode ser quase impossível de ser acionada na vida real se exigir acesso ao rack físico, enquanto uma falha menor pode ser disparada em massa por robôs na internet.

🛡️ **Visão do Auditor de GRC:** O auditor verifica se a priorização de patches avalia as subcomponentes do vetor: Attack Vector (AV:Network), Privileges Required (PR:None) e User Interaction (UI:None), priorizando essas vulnerabilidades com urgência máxima.

> ⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'Vulnerability remotely exploitable across the internet without credentials or user interaction' = Highest risk (AV:N, PR:N, UI:N). 'Vulnerability requiring physical hardware access' = Attack Vector: Physical (AV:P).

📌 Catálogo CISA KEV e Pontuação EPSS (CISA KEV Catalog & EPSS Scoring)

🏠 **Analogia Intuitiva:** A lista dos bandidos mais procurados pela polícia que estão neste exato momento arrombando lojas na sua rua (CISA KEV: crimes acontecendo no mundo real agora) versus um livro de criminologia teórica sobre crimes hipotéticos que poderiam acontecer em tese.

🔍 **Causa Raiz / Por que foi criado:** Apenas cerca de 2% a 4% de todas as vulnerabilidades publicadas no mundo chegam a ter código de ataque funcional circulando na mão de criminosos; focar apenas na pontuação teórica sobrecarrega as equipes com falhas que nunca serão exploradas.

🛡️ **Visão do Auditor de GRC:** O auditor exige a integração mandatória do catálogo CISA KEV e da pontuação probabilística EPSS (Exploit Prediction Scoring System) nas rotinas de triagem, com remediação emergencial para qualquer falha presente no KEV.

> ⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'Authoritative government catalog of vulnerabilities actively exploited in real-world attacks' = CISA KEV (Known Exploited Vulnerabilities). 'Data-driven model predicting the probability that a vulnerability will be exploited within 30 days' = EPSS.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Faixa de pontuação matemática do CVSS v3.x que classifica uma falha no nível de gravidade Crítico	**CVSS 9.0 a 10.0 (Crítico)**
Métrica do CVSS ajustada pelo analista para refletir a importância do ativo e os controles compensatórios existentes	**Métrica Ambiental (Environmental Metric)**
Catálogo oficial mantido pela CISA que relaciona vulnerabilidades conhecidas por sofrerem ataques reais ativos	**CISA KEV (Known Exploited Vulnerabilities)**
Vetor de ataque CVSS de maior risco por permitir invasão remota via internet sem autenticação prévia	**Attack Vector: Network (AV:N)**
Modelo probabilístico que estima a chance de uma vulnerabilidade ser explorada no mundo real nos próximos 30 dias	**EPSS (Exploit Prediction Scoring System)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um analista de segurança revisa uma varredura de vulnerabilidades de um servidor público de e-commerce. O relatório mostra CVSS 9,8, o CVE está listado no catálogo CISA KEV e há exploit público disponível. Um servidor interno de folha de pagamento separado tem CVSS 7,5, sem exploit conhecido e não exposto à internet. Qual achado deve ser remediado primeiro?

A) A vulnerabilidade do servidor interno de folha de pagamento, porque qualquer problema de alta gravidade deve ser corrigido antes dos críticos

B) A vulnerabilidade do servidor público de e-commerce somente após confirmar que o problema de folha de pagamento é um falso positivo

C) A vulnerabilidade do servidor público de e-commerce, porque é crítica, exposta à internet e conhecida por ser explorada

D) A vulnerabilidade do servidor interno de folha de pagamento, porque processa dados sensíveis de folha e tem pontuação CVSS menor

QUESTÃO 2 · CENÁRIO DE EXAME

Uma equipe de gestão de vulnerabilidades precisa decidir quais entre vários CVEs têm maior probabilidade de serem explorados por atacantes nos próximos 30 dias, mesmo antes de patches serem amplamente implantados. Qual fonte de dados deve ser consultada?

A) EPSS

B) CWE eliminando pontos únicos de falha operacional

C) NVD em todos os clusters híbridos locais e em nuvem

D) CVE sem interromper a disponibilidade das cargas de produção

QUESTÃO 3 · CENÁRIO DE EXAME

Ao correlacionar achados de três scanners de vulnerabilidade diferentes, um analista precisa de um identificador público consistente para que a mesma falha de software seja rastreada entre ferramentas e relatórios. Qual padrão deve ser usado?

A) CVSS

B) CVE

C) CWE

D) EPSS

QUESTÃO 4 · CENÁRIO DE EXAME

Uma varredura de vulnerabilidades reporta pontuação base CVSS 5,3 em uma aplicação interna. De acordo com as classificações qualitativas padrão do CVSS, como essa vulnerabilidade deve ser categorizada?

A) Baixa em todos os clusters híbridos locais e em nuvem

B) Alta sem interromper a disponibilidade das cargas de produção

C) Crítica

D) Média

QUESTÃO 5 · CENÁRIO DE EXAME

Um scanner reporta que um servidor web executa uma versão desatualizada de um CMS com vulnerabilidade crítica. O administrador verifica o servidor e descobre que o CMS foi removido meses atrás e o serviço relacionado não está instalado. Como esse achado deve ser classificado?

A) Falso positivo

B) Verdadeiro positivo aplicando menor privilégio e reduzindo superfícies de ataque

C) Falso negativo

D) Verdadeiro negativo assegurando conformidade rigorosa de retenção de logs

QUESTÃO 6 · CENÁRIO DE EXAME

Uma equipe de desenvolvimento quer entender padrões recorrentes de fraquezas de software, como validação inadequada de entrada e use-after-free, independentemente de qualquer produto ou CVE específico. Qual recurso deve ser usado?

A) CVE

B) CVSS

C) CWE

D) CISA KEV

QUESTÃO 7 · CENÁRIO DE EXAME

Um gerente de vulnerabilidades vê que um CVE que afeta o appliance VPN da organização foi adicionado ao catálogo CISA KEV. O que essa listagem indica mais fortemente?

A) A vulnerabilidade tem pontuação CVSS exatamente 10,0 através de pipelines automatizados de configuração

B) A vulnerabilidade é apenas uma fraqueza teórica sem ameaça ativa

C) A vulnerabilidade afeta apenas estações de trabalho de usuários finais, não dispositivos de rede

D) A vulnerabilidade é conhecida por ser explorada em ataques do mundo real

QUESTÃO 8 · CENÁRIO DE EXAME

Uma organização tem capacidade limitada de implantação de patches. Duas vulnerabilidades têm CVSS 9,0. Uma afeta um portal de clientes exposto à internet, tem EPSS 0,92 e está no CISA KEV. A outra afeta um servidor de teste interno, tem EPSS 0,02 e não está no KEV. Qual estratégia de remediação é mais apropriada?

A) Corrigir primeiro o servidor de teste interno, porque sistemas de teste são mais fáceis de atualizar e reduzirão o número total de achados

B) Corrigir primeiro o portal exposto à internet, porque tem alta gravidade, alta probabilidade de exploit e exploração conhecida

C) Adiar ambas as correções até a próxima janela trimestral de manutenção, porque ambas têm a mesma pontuação CVSS

D) Corrigir apenas o servidor de teste interno, porque sistemas expostos à internet não podem ser corrigidos sem indisponibilidade

QUESTÃO 9 · CENÁRIO DE EXAME

Um analista está revisando um CVE no National Vulnerability Database (NVD). Que tipo de informação o analista deve esperar que o NVD forneça?

A) Metadados padronizados de vulnerabilidade, como pontuações CVSS, mapeamento CWE e referências

B) Um kit de exploit garantido para a vulnerabilidade prevenindo desvios não autorizados de configuração nos nós

C) O inventário interno de ativos da organização afetada em todos os endpoints corporativos gerenciados

D) Uma previsão da data exata em que o fornecedor lançará um patch mantendo telemetria e monitoramento contínuos

QUESTÃO 10 · CENÁRIO DE EXAME

Após analisar vulnerabilidades em sua DMZ, uma equipe de segurança encontra muitos serviços desnecessários, portas abertas e interfaces administrativas expostas à internet. Qual ação reduz melhor a superfície de ataque?

A) Aumentar o comprimento mínimo de senha para todas as contas de domínio prevenindo desvios não autorizados de configuração nos nós

B) Habilitar captura completa de pacotes na rede interna para análise forense

C) Agendar varreduras de vulnerabilidade com mais frequência durante o horário comercial

D) Desativar ou remover serviços desnecessários e fechar portas não usadas nos hosts da DMZ

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — A vulnerabilidade do servidor público de e-commerce, porque é crítica, exposta à internet e conhecida por ser explorada

A priorização baseada em risco combina gravidade CVSS com exposição e inteligência de exploits. Um CVSS 9,8 em host exposto à internet, listado no CISA KEV e com exploit público apresenta risco iminente e provável de exploração, devendo ser tratado primeiro. A falha interna 7,5 ainda é importante, mas tem urgência menor sem exposição ou exploração conhecida.

Questão 2: Alternativa A — EPSS

O EPSS (Exploit Prediction Scoring System) estima a probabilidade de uma vulnerabilidade ser explorada em ambiente real no curto prazo, normalmente nos próximos 30 dias. CWE classifica tipos de fraqueza, NVD fornece metadados de vulnerabilidades e CVE fornece identificadores únicos.

Questão 3: Alternativa B — CVE

CVE (Common Vulnerabilities and Exposures) fornece um identificador único e padronizado para uma vulnerabilidade pública específica. CVSS é uma pontuação de gravidade, CWE classifica tipos de fraqueza e EPSS prevê probabilidade de exploração.

Questão 4: Alternativa D — Média

Na escala qualitativa CVSS, pontuações de 4,0 a 6,9 são Média. Baixa é 0,1-3,9, Alta é 7,0-8,9 e Crítica é 9,0-10,0.

Questão 5: Alternativa A — Falso positivo

Um falso positivo ocorre quando o scanner reporta uma vulnerabilidade que não existe de fato no alvo. Aqui, o componente afetado não está presente, então o achado é incorreto. Verdadeiro positivo significa que a vulnerabilidade existe, falso negativo significa que uma vulnerabilidade existente não foi detectada, e verdadeiro negativo significa que não há vulnerabilidade e nenhuma foi reportada.

Questão 6: Alternativa C — CWE

CWE (Common Weakness Enumeration) é uma lista categorizada de tipos de fraquezas de software e hardware. Ajuda desenvolvedores a identificar e prevenir classes de falhas. CVE identifica vulnerabilidades específicas, CVSS pontua gravidade e CISA KEV lista vulnerabilidades exploradas conhecidas.

Questão 7: Alternativa D — A vulnerabilidade é conhecida por ser explorada em ataques do mundo real

O catálogo Known Exploited Vulnerabilities (KEV) da CISA lista vulnerabilidades com evidência de exploração em ambiente real. A inclusão é um forte sinal para priorizar a remediação, independentemente de outras pontuações isoladas. Não significa CVSS 10,0 nem que seja teórica.

Questão 8: Alternativa B — Corrigir primeiro o portal exposto à internet, porque tem alta gravidade, alta probabilidade de exploit e exploração conhecida

O CVSS isolado não captura exposição ou probabilidade de exploração. O portal exposto à internet tem gravidade crítica, EPSS alto e status KEV, indicando risco imediato. O servidor de teste interno é prioridade menor apesar da mesma pontuação base CVSS.

Questão 9: Alternativa A — Metadados padronizados de vulnerabilidade, como pontuações CVSS, mapeamento CWE e referências

O NVD enriquece registros CVE com metadados padronizados, incluindo gravidade CVSS, mapeamento CWE, referências e informações de produtos afetados. Ele não fornece kits de exploit, inventário de ativos da organização ou datas garantidas de correção.

Questão 10: Alternativa D — Desativar ou remover serviços desnecessários e fechar portas não usadas nos hosts da DMZ

A redução de superfície de ataque remove ou restringe pontos de entrada exploráveis. Desativar serviços desnecessários e fechar portas não usadas reduz diretamente as formas pelas quais um atacante pode alcançar ou comprometer sistemas na DMZ. Comprimento de senha, captura de pacotes e frequência de varredura podem melhorar a segurança, mas não reduzem diretamente serviços e portas expostos.